

Security Vulnerability Report

Indrajala Movie Makers LLP

Reporter	Sahil Maurya
Email	sahilmaurya2575@gmail.com
Date of Discovery	21/03/2026
Date of Submission	21/03/2026
Submitted To	security@indrajala.in
Program	Indrajala Bug Bounty — Terms of Service, Section 5
Severity	High
CVE Referenced	CVE-2026-1707 (GHSA-3p7x-94q9-jq9x)
Affected Assets	api.indrajala.in / dbcore.indrajala.in

Submitted under Indrajala's official Bug Bounty Program (ToS §5 — Platform Security & Integrity). No exploitation occurred. No data was accessed. No public disclosure prior to this submission. Rewards per ToS: \$100–\$5,000 based on severity.

1 Summary

Three compounding misconfigurations expose a pgAdmin 4 database administration interface publicly via api.indrajala.in and dbcore.indrajala.in:

- The API domain routes HTTPS traffic to a pgAdmin backend while serving a default nginx page over HTTP.
- The TLS certificate on api.indrajala.in is issued for dbcore.indrajala.in — confirming improper virtual host binding.
- The pgAdmin login endpoint has no rate limiting, making brute-force attacks unrestricted.

The instance runs **pgAdmin 4 v9.11.0** (confirmed via HTML source fingerprinting), which is affected by CVE-2026-1707. Combined with absent rate limiting, this creates a complete attack chain from unauthenticated discovery to remote code execution.

2 Affected Assets

Asset	Protocol	Issue
api.indrajala.in	HTTP	Default nginx page — routing inconsistency
api.indrajala.in	HTTPS	Routes to pgAdmin; wrong TLS cert served
dbcore.indrajala.in	HTTPS	pgAdmin 4 v9.11.0 — public, no rate limiting

3 Technical Findings

F 1 Protocol-Dependent Backend Routing

api.indrajala.in serves a different backend depending on protocol. HTTP returns a default nginx page; HTTPS proxies to pgAdmin. This is caused by a misconfigured nginx catch-all HTTPS server block.

```
curl -i http://api.indrajala.in
HTTP/1.1 200 OK | Server: nginx/1.26.3 | Welcome to nginx!

curl -k -i https://api.indrajala.in
HTTP/1.1 302 Found
Location: /login?next=/
Set-Cookie: pga4_session=...; HttpOnly # confirms pgAdmin 4 backend
```

F 2 TLS Certificate Misbinding

The TLS certificate served by api.indrajala.in:443 is issued for dbcore.indrajala.in. This confirms the nginx HTTPS virtual host is bound to the wrong backend upstream.

```
openssl s_client -connect api.indrajala.in:443 2>/dev/null | grep subject
subject=CN=dbcore.indrajala.in # CN does not match queried domain
```

F
3

pgAdmin 4 v9.11.0 Publicly Accessible

The pgAdmin 4 administration panel is directly reachable from the public internet with no network restriction. It provides full database access: query execution, schema browsing, data export, backup and restore. It should only be accessible via VPN or IP allowlist.

```
https://dbcore.indrajala.in/login # direct access
https://api.indrajala.in # redirects to pgAdmin login
```

Version Confirmation — pgAdmin 4 v9.11.0

Version confirmed via HTML source asset fingerprinting. All static asset URLs in the page source contain the parameter ver=91100, which maps directly to pgAdmin version 9.11.0:

```
# From page source at dbcore.indrajala.in/login:
style.css?ver=91100
vendor.react.js?ver=91100
/favicon.ico?ver=91100
# ver=91100 = pgAdmin 4 version 9.11.0
```

Additional Confirmation — pgAdmin API Response

The pgAdmin internal API endpoint responded with a pgAdmin-specific JSON error format, further confirming the backend identity independently of asset URLs:

```
GET https://dbcore.indrajala.in/misc/upgrade_check

Response:
{
  "success": 0,
  "errmsg": "The CSRF token is missing. You need to refresh the page.",
  "info": "",
  "result": null,
  "data": null
}

# This JSON structure is unique to pgAdmin 4.
# Internal API endpoint publicly reachable without authentication.
```

Browser screenshot attached as Exhibit A confirms live public access with date timestamp 21-03-2026 visible in system taskbar.

F
4

No Rate Limiting on Authentication Endpoint

POST /authenticate/login has no rate limiting, account lockout, or CAPTCHA. Thirty consecutive failed login attempts produced no blocking, no delay, and no change in response at any threshold.

```
for i in {1..30}; do
curl -s -o /dev/null -w "%{http_code}\n" -X POST \
https://dbcore.indrajala.in/authenticate/login \
-d '{"username":"test@test.com","password":"wrongpassword"}'
done

401 401 401 401 401 401 401 401 401 401 # all 30 requests
401 401 401 401 401 401 401 401 401 401
401 401 401 401 401 401 401 401 401 401

# No 429. No blocking. No CAPTCHA. No delay at any point.
```

Indrajala ToS §5 explicitly prohibits brute force attacks on authentication systems. This finding confirms there is currently no technical control preventing them.

F
5

Vulnerable pgAdmin Version — CVE-2026-1707

pgAdmin 4 v9.11.0 is below the patched threshold for CVE-2026-1707.

CVE-2026-1707 — Restore Restriction Bypass via Key Disclosure

Affected: pgAdmin 4 < 9.12 · Patched: v9.12 · Vector: Network · Complexity: Low · Privileges: Low (authenticated)

When pgAdmin runs in server mode and performs PLAIN-format dump restores, an authenticated attacker can observe an active restore, extract the \restrict key in real time, and overwrite the restore script to inject arbitrary commands. This results in command execution on the pgAdmin host.

Note: CVE-2026-1707 requires authenticated access. It is cited as the terminal step of the attack chain made possible by F3 and F4. The vulnerability was not actively triggered or tested.

4 Attack Chain

Each step is directly enabled by a confirmed finding above. This is a practical sequence, not a theoretical scenario.

Step 1	Discover pgAdmin via HTTPS on api.indrajala.in HTTPS request redirects to pgAdmin login. Enabled by F1 + F2.
Step 2	Confirm second entry point at dbcore.indrajala.in/login Same panel accessible directly. Two public entry points confirmed. Enabled by F3.
Step 3	Brute-force credentials — no blocking, no CAPTCHA Automated login attempts with no rate limit or lockout. Enabled by F4.
Step 4	Obtain authenticated access to pgAdmin Full access to database admin panel: queries, schema, backup, restore.
Step 5	Exploit CVE-2026-1707 via restore operation Trigger PLAIN-format restore, extract \restrict key, inject command payload. Enabled by F5.
Step 6	Remote code execution + full database compromise Arbitrary commands execute on host. Full DB access and lateral movement possible.

5 Impact

Indrajala handles creator subscriptions and fan payments. Successful exploitation exposes:

PII of all creators and fans	Names, emails, account details of all registered users.
Payment and transaction records	Subscription histories, financial data, creator earnings.
Remote code execution	CVE-2026-1707 enables command execution on pgAdmin host.
Premium content metadata	Access tokens, content references, creator IP.
Full database schema	Enables targeted attacks on other platform endpoints.

6 Recommended Fixes

P1	Restrict pgAdmin behind VPN or IP allowlist immediately. Remove public access to dbcore.indrajala.in.
-----------	---

- P1** Add rate limiting to POST /authenticate/login — max 5 attempts/5 min/IP, CAPTCHA after 3 failures, lockout after 10.
- P1** Upgrade pgAdmin 4 to v9.12 or later to patch CVE-2026-1707.
- P2** Fix nginx virtual host config — give each domain its own server block with explicit server_name. Remove the catch-all HTTPS block.
- P2** Bind the correct TLS certificate to each domain separately.
- P3** Remove default nginx page from production and add firewall rules blocking internal admin ports from public-facing domains.

7 Exhibit A — Visual Proof

Screenshot captured on 21/03/2026 confirming live public access to pgAdmin 4 at dbcore.indrajala.in. URL bar and system date (21-03-2026) are clearly visible.

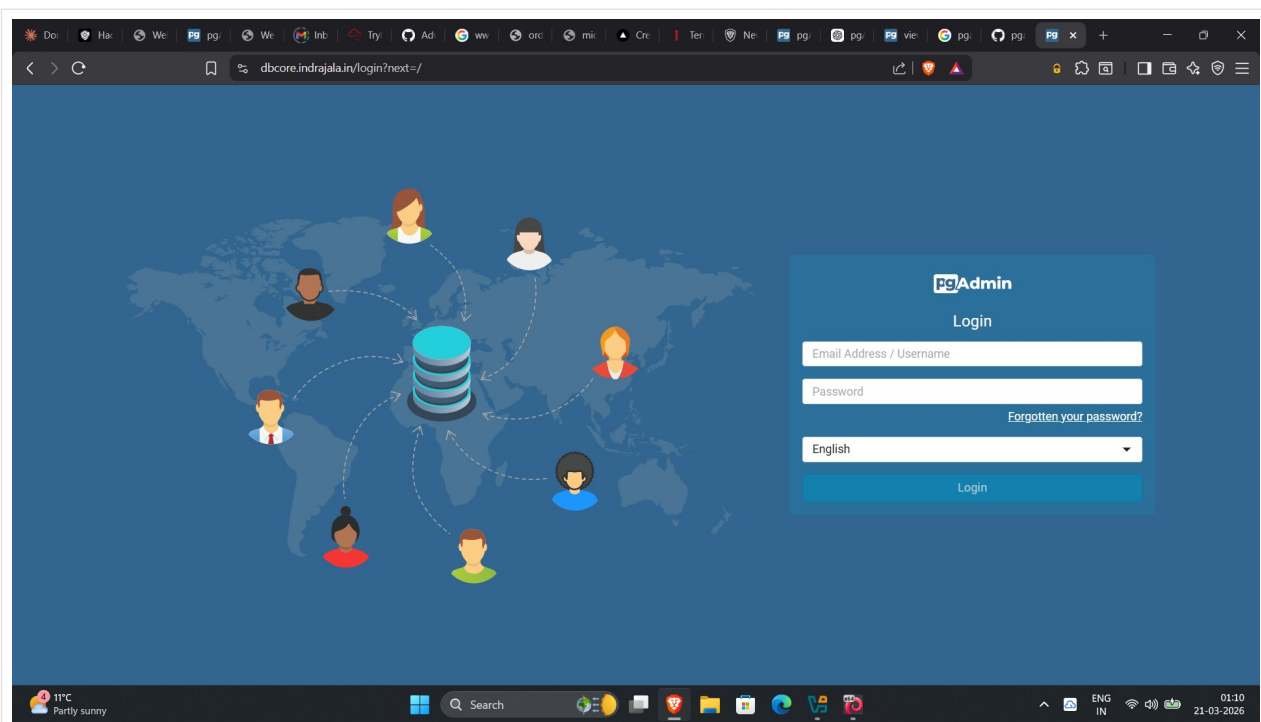


Exhibit A — dbcore.indrajala.in/login?next=/ · pgAdmin 4 · Date: 21-03-2026

8 Ethics Statement

All testing was passive and non-destructive. No login was successfully performed. The rate limit test used only deliberate wrong credentials. No data was accessed or exfiltrated. CVE-2026-1707 was not triggered. All activity was limited to confirming observable, unauthenticated behavior. This report is submitted in good faith and the researcher requests acknowledgment per Indrajala ToS Section 5.

9 References

- GHSA-3p7x-94q9-jq9x — CVE-2026-1707 · github.com/advisories/GHSA-3p7x-94q9-jq9x
- NVD — CVE-2026-1707 · nvd.nist.gov/vuln/detail/CVE-2026-1707
- pgAdmin 4 v9.12 Release Notes · pgadmin.org
- OWASP A07:2021 — Identification and Authentication Failures
- OWASP A05:2021 — Security Misconfiguration
- Indrajala Terms of Service §5 · indrajala.in/terms

Sahil Maurya

sahilmaurya2575@gmail.com · 21/03/2026